

Reporte de Auditoría de Ciberseguridad - Servidor Linux

Fecha del Reporte: 26 de Mayo de 2024 **Auditor:** Consultor Senior en Ciberseguridad **Servidor Auditado (IP HASH):** 36c250cd5df6a0d461a6e5ec6e166bbe78f995dc273b98c690ce611baf21acc4 **Sistema Operativo:** Ubuntu Server **Origen de Datos:** Script Python basado en CIS Benchmarks

1. Resumen Ejecutivo

Este reporte detalla los hallazgos de seguridad críticos detectados en el servidor Linux auditado, con un enfoque en la gestión de cuentas de usuario y la exposición de servicios de red. Se han identificado configuraciones altamente inseguras que representan un riesgo significativo para la integridad, confidencialidad y disponibilidad del sistema.

Score de Seguridad: 20/100 (Crítico)

El score de seguridad es alarmantemente bajo debido a la detección de acceso interactivo para la cuenta root y para una cuenta de sistema (sync) con una shell inusual, lo que abre múltiples vectores de ataque para la escalada de privilegios y el compromiso total del sistema. La exposición de servicios como SSH sin endurecimiento adicional agrava estos riesgos. Se requiere una acción inmediata para mitigar estas vulnerabilidades.

2. Hallazgos Prioritarios

Se han identificado los siguientes hallazgos como de máxima prioridad, que requieren atención y remediación inmediatas:

Acceso Interactivo para la Cuenta root (UID 0): La cuenta root tiene configurada una shell interactiva (/bin/bash) y está habilitada para iniciar sesión ("tiene_login": true). Esto es una práctica de seguridad extremadamente deficiente, especialmente si se combina con acceso remoto (ej. SSH), ya que un compromiso de esta cuenta otorga control total e ilimitado sobre el sistema. El principio de menor privilegio dictamina que el acceso root debe limitarse a través de sudo desde cuentas de usuario estándar.

Cuenta de Sistema sync (UID 4) con Acceso Interactivo y Shell Inapropiada: La cuenta sync, un usuario de sistema, está configurada con acceso interactivo ("tiene_login": true) y su shell es /bin/sync. Esta configuración es altamente anómala y peligrosa. La shell /bin/sync no está diseñada para sesiones interactivas y su uso de esta manera es una grave misconfiguración que podría ser explotada para ejecución de comandos arbitrarios, escalada de privilegios o denegación de servicio. Las cuentas de sistema no deben tener shells interactivas.

Exposición del Servicio SSH (Puerto 22/TCP) sin Endurecimiento Aparente: El servicio SSH está abierto y accesible. Aunque SSH es una herramienta esencial para la administración remota, su exposición, especialmente en conjunción con la posibilidad de login directo de root o de otras cuentas con contraseñas débiles, lo convierte en un objetivo principal para ataques de fuerza bruta o credenciales robadas.

Exposición del Servicio DNS (Puerto 53/TCP): El puerto 53/TCP está abierto. Aunque este puerto es común para servicios DNS (especialmente para transferencias de zona o consultas DNS grandes), su exposición sin una configuración adecuada puede llevar a vulnerabilidades como ataques de denegación de servicio (DDoS amplification), fugas de información (enumeración de zonas) o explotación de vulnerabilidades en el software DNS si no está actualizado o correctamente configurado.

3. Tabla de Riesgos

ID	Riesgo	Impacto	Probabilidad	Nivel de Riesgo	Descripción
R-001	Compromiso de la cuenta root	Crítico (Completo)	Alta	CRÍTICO	Un atacante que logre obtener las credenciales de root tendrá control total e ilimitado sobre el sistema, pudiendo robar datos, instalar malware, crear puertas traseras o destruir la información.
R-002	Explotación de la cuenta sync	Alto	Media	ALTO	La configuración anómala de la cuenta sync podría permitir a un atacante ejecutar comandos, elevar privilegios o causar inestabilidad en el sistema. Es un vector de ataque inesperado que podría pasar desapercibido.

R-003	Ataques de Fuerza Bruta/Credenciales en SSH	Alto	Alta	ALTO	La exposición de SSH, especialmente con múltiples usuarios y el login de root potencialmente habilitado, hace que el servidor sea vulnerable a intentos de fuerza bruta y ataques de diccionario para obtener acceso no autorizado.
R-004	Vulnerabilidades y Explotación de Servicio DNS	Medio	Media	MEDIO	Si el servicio DNS no está correctamente configurado (ej. recursión abierta, transferencias de zona sin restricción) o no está actualizado, puede ser objetivo de ataques DDoS, envenenamiento de caché o exfiltración de información.
R-005	Compromiso de Cuentas de Usuario Estándar	Medio	Media	MEDIO	Las cuentas de usuario uid=1000 y uid=1001 con acceso interactivo, si sus contraseñas son débiles o son comprometidas, pueden servir como punto de entrada para un atacante para intentar escalada de privilegios.

4. Recomendaciones Técnicas

Se recomienda la implementación inmediata de las siguientes medidas para mitigar los riesgos identificados:

4.1. Gestión de Cuentas de Usuario

a) Deshabilitar el acceso interactivo directo para la cuenta root

- **Crear un usuario administrativo con privilegios sudo:** bash # Crear un nuevo usuario (reemplaza 'adminuser' con un nombre apropiado) sudo adduser adminuser # Añadir el usuario al grupo 'sudo' para conceder privilegios de administrador sudo usermod -aG sudo adminuser

Deshabilitar el inicio de sesión SSH para root:

1. Editar el archivo de configuración de SSH: bash sudo nano /etc/ssh/sshd_config
2. Buscar la línea PermitRootLogin y cambiarla a: PermitRootLogin no (Si la línea está comentada con #, descomentar y cambiar el valor).
3. Reiniciar el servicio SSH: bash sudo systemctl restart sshd # 0 para sistemas más antiguos: # sudo service ssh restart
4. **Nota:** Asegúrese de poder iniciar sesión con el nuevo adminuser antes de reiniciar SSH y desconectar su sesión root actual.

Considerar deshabilitar el acceso interactivo local para root (si el acceso a través de consola física es un riesgo): bash sudo usermod -s /usr/sbin/nologin root

- **Advertencia:** Esto impedirá que root inicie sesión localmente. Solo realice esto si está completamente seguro de que el acceso sudo es suficiente para todas las tareas administrativas.

b) Corregir la configuración de la cuenta de sistema sync

- **Cambiar la shell de la cuenta sync a nologin:** bash sudo usermod -s /usr/sbin/nologin sync Esto asegurará que la cuenta sync no pueda iniciar sesiones interactivas.

c) Reforzar las contraseñas de los usuarios interactivos

- Asegúrese de que adminuser, uid=1000, uid=1001 tengan contraseñas fuertes y únicas.
- Implementar políticas de complejidad de contraseñas.

- Considerar el uso de autenticación de clave SSH en lugar de contraseñas para todos los usuarios remotos.

4.2. Endurecimiento de Servicios de Red

a) Endurecimiento de SSH (Puerto 22/TCP)

Deshabilitar la autenticación por contraseña (reemplazar con claves SSH):

1. Editar el archivo de configuración de SSH (/etc/ssh/sshd_config).
2. Cambiar: PasswordAuthentication no
3. Asegurarse de que PubkeyAuthentication yes esté habilitado.
4. Reiniciar SSH: sudo systemctl restart sshd.
5. **Nota:** Asegúrese de que todos los usuarios que necesitan acceso remoto tengan sus claves SSH configuradas *antes* de deshabilitar la autenticación por contraseña.

Limitar el número de intentos de autenticación:

1. Editar el archivo de configuración de SSH (/etc/ssh/sshd_config).
 2. Añadir o modificar: MaxAuthTries 3
 3. Reiniciar SSH: sudo systemctl restart sshd.
- **Instalar y configurar fail2ban:** fail2ban bloquea automáticamente IPs que intentan repetidamente autenticarse sin éxito. bash sudo apt update sudo apt install fail2ban # Copiar la configuración por defecto para crear una personalizada sudo cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local # Editar /etc/fail2ban/jail.local para ajustar los parámetros (ej. bantime, findtime) sudo nano /etc/fail2ban/jail.local # Asegurarse de que el jail de sshd esté habilitado: # [sshd] # enabled = true # Reiniciar fail2ban sudo systemctl restart fail2ban

Considerar cambiar el puerto por defecto de SSH (opcional): Cambiar el puerto 22 a un puerto no estándar (ej. 2222) reduce el ruido de escaneos automatizados, aunque no es una medida de seguridad definitiva.

1. Editar el archivo de configuración de SSH (/etc/ssh/sshd_config).

2. Cambiar: Port 22 A: Port 2222 # 0 cualquier otro puerto no utilizado

3. Añadir la regla al firewall (ej. UFW): `bash sudo ufw allow 2222/tcp sudo ufw delete allow 22/tcp # Eliminar la regla anterior para el puerto 22`

4. Reiniciar SSH: `sudo systemctl restart sshd.`

5. **Importante:** Asegúrese de actualizar las configuraciones de firewall y clientes SSH después de cambiar el puerto.

b) Revisión y Endurecimiento de DNS (Puerto 53/TCP)

- **Identificar el servicio DNS:** Determine qué software está escuchando en el puerto 53/TCP (ej. BIND, dnsmasq). `bash sudo netstat -tulpn | grep :53 # 0 con ss sudo ss -tulpn | grep :53`
- **Si el servicio DNS no es necesario:** Deshabilítelo y desinstálelo si no tiene una función legítima. `bash # Ejemplo para BIND sudo systemctl stop named sudo systemctl disable named sudo apt remove bind9 # 0 para dnsmasq sudo systemctl stop dnsmasq sudo systemctl disable dnsmasq sudo apt remove dnsmasq`

Si el servicio DNS es necesario:

1. **Restringir las transferencias de zona (para servidores autoritativos):** Asegúrese de que las transferencias de zona estén estrictamente limitadas a IPs de servidores DNS secundarios conocidos. En BIND, en `named.conf.local` o `named.conf.options`: `allow-transfer { your_secondary_dns_ip; };`
2. **Restringir la recursión (para servidores recursivos):** La recursión debe limitarse a las redes internas o clientes específicos que la necesiten, no al mundo exterior. En BIND: `allow-recursion { your_internal_network; };`
3. **Mantener el software DNS actualizado:** Asegúrese de que el software DNS esté siempre en su última versión estable para protegerse contra vulnerabilidades conocidas.
4. **Implementar reglas de firewall específicas:** Restrinja el acceso al puerto 53/TCP solo a las IPs y redes que *realmente* necesitan interactuar con el servicio DNS. `bash # Ejemplo para UFW (Ubuntu Firewall) # Permite acceso DNS (TCP y UDP) desde una red específica sudo ufw allow from 192.168.1.0/24 to any port 53 proto tcp sudo ufw allow from 192.168.1.0/24 to any port 53 proto udp # Deniega el acceso a DNS desde cualquier otro lugar si no hay otras reglas que lo permitan # (Asegúrese de que UFW esté habilitado y configurado correctamente) # sudo ufw enable`

4.3. Recomendaciones Generales

- **Actualizaciones del sistema:** Mantener el sistema operativo y todas las aplicaciones actualizadas regularmente. `bash sudo apt update && sudo apt upgrade -y sudo apt dist-upgrade -y`

- **Auditoría y monitoreo de logs:** Implementar un sistema de gestión de logs (SIEM) para monitorear eventos de seguridad, inicios de sesión y actividad sospechosa.
 - **Principio de mínimo privilegio:** Asegúrese de que los usuarios y servicios tengan solo los permisos necesarios para realizar sus funciones.
 - **Autenticación de Múltiples Factores (MFA):** Considere implementar MFA para el acceso SSH para una capa adicional de seguridad.
-

5. Metadata de la Auditoría

- **Origen de los Datos:** Script Python
 - **Estándar de Referencia:** CIS Benchmarks
-

6. Descargo de Responsabilidad

Este reporte se basa en la información proporcionada en el JSON de auditoría. Las recomendaciones se formulan en base a las mejores prácticas de seguridad actuales. La implementación de estas recomendaciones es responsabilidad del propietario del sistema y debe realizarse con precaución, probando los cambios en un entorno de desarrollo antes de aplicarlos en producción. Este reporte no garantiza la eliminación de todas las vulnerabilidades, ya que el panorama de amenazas está en constante evolución. Se recomienda realizar auditorías de seguridad periódicas y pruebas de penetración.